

Cyber Security Operations Platform

AI SOC, Detection Engineering and SOAR Specification

Document purpose

This document is part of a build-and-operate pack for a modular Cyber Security Operations Platform capable of SOC-as-a-Service, MDR, Managed XDR, sovereign SOC, enterprise private SOC, and MSSP white-label deployments.

1. Design philosophy

The AI capability should augment analysts, not operate as an uncontrolled autonomous responder. The system should provide explainable summaries, evidence-linked recommendations, risk scoring, and safe automation under tenant-defined authority-to-act.

2. AI SOC assistant capabilities

Capability	Description	Safety control
Alert summarisation	Summarise what happened, impacted entities and why it matters.	Must reference available event evidence and confidence level.
Investigation planning	Suggest next queries, data sources and enrichment steps.	Analyst chooses actions; suggestions logged.
Incident timeline drafting	Create chronological timeline from events, notes and playbook steps.	Timeline must be editable and show source event links.
MITRE mapping	Suggest tactics/techniques from event context.	Detection engineer can approve/change mapping.
Customer update drafting	Draft plain-English incident updates and closure reports.	Human approval required before sending.
Detection tuning suggestion	Identify noisy rules and possible tuning conditions.	Detection engineer approval and regression test required.
Playbook recommendation	Recommend playbooks based on alert category and impacted entities.	Authority-to-act and approval gates enforced.
Executive summary	Generate board-friendly monthly and incident summaries.	Customer success/SOC lead review before release.

3. AI guardrails

Risk	Guardrail
Hallucinated facts	AI outputs must distinguish observed evidence from inference and uncertainty.
Cross-tenant data leakage	Strict tenant retrieval scoping, prompt isolation and automated tests.
Unsafe containment	AI cannot execute destructive/containment actions; only SOAR engine can under approval policy.
Sensitive data exposure	Data minimisation, redaction and configurable model routing for regulated tenants.
Over-trust by analysts	UI must label AI as assistance; require analyst confirmation for severity and actions.
Regulatory/audit challenge	Keep prompt, context, model version, output and user decision logs.

4. Detection engineering lifecycle

Stage	Activities	Artifacts
Hypothesis	Define threat behaviour, use case, required telemetry and impacted customer types.	Detection design note.
Rule build	Create Sigma/native rule, map fields, define severity/confidence and MITRE mapping.	Rule YAML/config.
Test	Run against sample data and historical tenant data where authorised.	Test results and expected hits.
Peer review	Detection engineer/SOC lead review logic and false-positive risk.	Approval record.
Deploy	Release to relevant tenants/groups with feature flag and monitoring.	Release note.
Tune	Adjust allowlists, thresholds, field mappings and severity based on feedback.	Tuning history.
Retire/replace	Deprecate obsolete rules and maintain coverage mapping.	Retirement decision record.

5. Detection catalogue structure

Field	Purpose
Detection ID	Unique identifier and version.
Name and description	Human-readable detection intent.
Log source requirements	Required event classes, vendors and fields.
Rule logic	Sigma/native DSL/query expression.
Severity/confidence	Default scoring and conditions for upgrade/downgrade.
MITRE mapping	Tactics, techniques and sub-techniques where relevant.
False-positive notes	Expected benign scenarios and tuning guidance.
Response playbook	Default playbook and escalation path.
Test cases	Positive, negative and edge-case datasets.
Tenant overrides	Allowlist, suppression windows, threshold overrides and exceptions.

6. Initial detection use-case library

Domain	Use case	Data required	Default severity
Identity	Impossible travel followed by MFA change	Entra/Okta/Google identity logs	P2
Identity	MFA fatigue / repeated denied prompts	Entra/Okta MFA logs	P2
Email	Mailbox forwarding rule to external address	M365 audit/email logs	P2
Email	Phishing click plus risky sign-in	Email security + identity logs	P2
Endpoint	Suspicious PowerShell encoded command	EDR/Windows logs	P2/P3
Endpoint	Ransomware-like file rename pattern	EDR/file telemetry	P1/P2
Cloud	New admin access key created for privileged user	AWS/Azure/GCP logs	P2
Network	Outbound connection to known malicious IP/domain	Firewall/DNS/proxy logs	P2/P3
Vulnerability	Exploited critical vulnerability on internet-facing asset	Scanner + threat intel + asset data	P2/P1
Data	Large unusual outbound transfer from critical system	Network/cloud/storage logs	P1/P2

7. SOAR workflow requirements

Requirement	Description
Workflow designer	Admin/detection engineer can define playbook steps, conditions, approvals and actions.
Approval gates	Actions can require customer approval, SOC lead approval or both.
Dry run	Playbook can simulate actions and show intended impact.
Action connectors	Actions executed through controlled connectors with scoped credentials.
Rollback notes	Where technical rollback is not possible, the playbook must record recovery instructions.
Audit trail	Every playbook step records actor, timestamp, input, output and status.
Error handling	Retry, escalate or fail safely if connector errors occur.
Tenant policy	Each tenant defines allowed playbooks and authority-to-act.

8. Example playbook: suspected compromised account

Step	Action	Automation level
1	Enrich user: sign-ins, MFA changes, device, recent alerts, mailbox rules.	Automated evidence collection.
2	Assess severity based on privilege, risky sign-	AI-assisted/analyst approved.

	in, geo anomaly and activity after login.	
3	Check for malicious mailbox rules and OAuth grants.	Automated query.
4	Recommend session revocation and password reset.	AI suggestion/analyst review.
5	Request approval unless pre-authorised.	Workflow approval.
6	Revoke sessions, disable account or reset password using identity connector.	SOAR action.
7	Notify customer and create closure/remediation actions.	Drafted by AI, approved by analyst.

Reference standards and sources

NIST Cybersecurity Framework 2.0: <https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final>

NIST SP 800-61 Revision 3 Incident Response Recommendations: <https://csrc.nist.gov/pubs/sp/800/61/r3/final>

MITRE ATT&CK Enterprise Matrix: <https://attack.mitre.org/matrices/enterprise/>

OCSF Open Cybersecurity Schema Framework: <https://ocsf.io/>

Sigma Detection Format: <https://sigmahq.io/docs/basics/rules.html>

OASIS STIX/TAXII Cyber Threat Intelligence Standards: https://www.oasis-open.org/committees/tc_home.php?wg_abbrev=cti

CIS Critical Security Controls v8.1: <https://www.cisecurity.org/controls/v8-1>

FIRST Traffic Light Protocol 2.0: <https://www.first.org/tlp/>